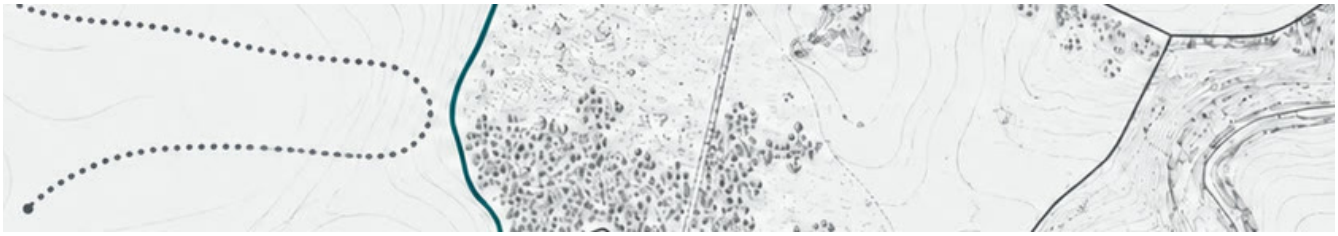
Identity governance for AI agents



Joiner-mover-leaver, recertification and ownership for an AI agent in government.

Michael Owen Meijer, Oomny B.V. · identity architect and AI engineer for government and cloud

The problem

Who owns this agent, should it still exist, and what happens when that owner leaves or changes teams? For employees, identity governance (IGA) addresses this through joiner-mover-leaver and recertification. A service account or API key alone does not provide that governance for an agent. Without an owner and an expiry date its access stays in place, even when nobody is responsible for it any more.

The approach

An agent goes through the same governance process as an employee:

- **Joiner.** The administrator provisions the agent through SCIM 2.0 with a human owner, a purpose, an expiry date and a risk class. Until the owner confirms it, the agent does nothing.
- **Mover.** The agent inherits its access from its owner's teams (agent → owner → team → case file in OpenFGA). When the owner changes teams, the agent is refused until a new confirmation, and its access then follows the new team. Nobody changes anything per agent.
- **Leaver.** When the owner leaves, the agent is deactivated and refused on its next tool call, even in the middle of a task. Its registration and audit trail are kept.
- **Recertification with a hard deadline.** The owner confirms the agent periodically. If that does not happen, or the expiry date has passed, the gateway refuses it. After the expiry date OpenFGA refuses it as well.
- **One log.** Lifecycle events and tool calls are in one hash chain with an anchor on a separate volume. A changed record or a truncated tail shows up.

The evidence

A public repository with a working demo in one command (`make demo`), without API keys. A LangGraph agent works on the case files of a fictional municipality through an MCP gateway. Five scenarios: joiner, prompt injection, mover, leaver in the middle of a task, and expiry without recertification. An instruction injected into a case file attachment sends the agent to a case of another team. That fails on the missing relation, not on the model's judgement. The demo ends with the evidence table from the log, a check of chain and anchor, and a tampering test.

236 unit tests, 36 integration tests against the real stack and model tests for OpenFGA. A threat model against the OWASP Top 10 for Agentic Applications 2026 and the OWASP Non-Human Identities Top 10, with the test behind each control. An honest section on what this does not solve.

Why me

Identity and security since 2011, nearly eight years for the four largest Dutch municipalities: identity synchronisation with MIM, SCIM provisioning from the municipalities, PIM with access reviews in Entra ID, and setting up Keycloak (cutover in preparation). Since 2026 I have been building AI agents with tool calling and MCP. For employees this governance process has been routine for years; for agents it is only starting.

Repo: github.com/oomny-nl/agent-levenscyclus · **Site:** www.oomny.nl · **Mail:** michael@oomny.nl